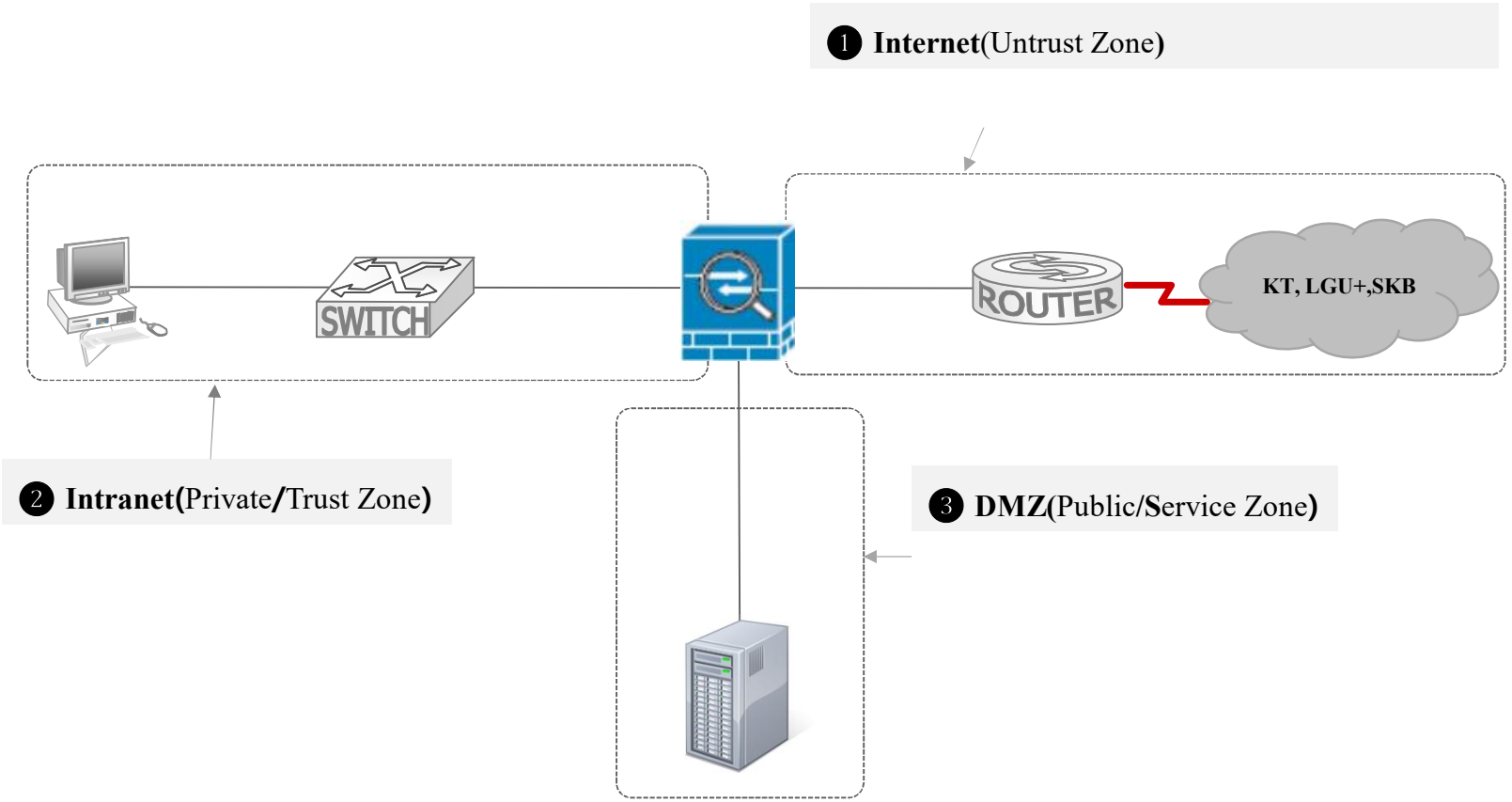
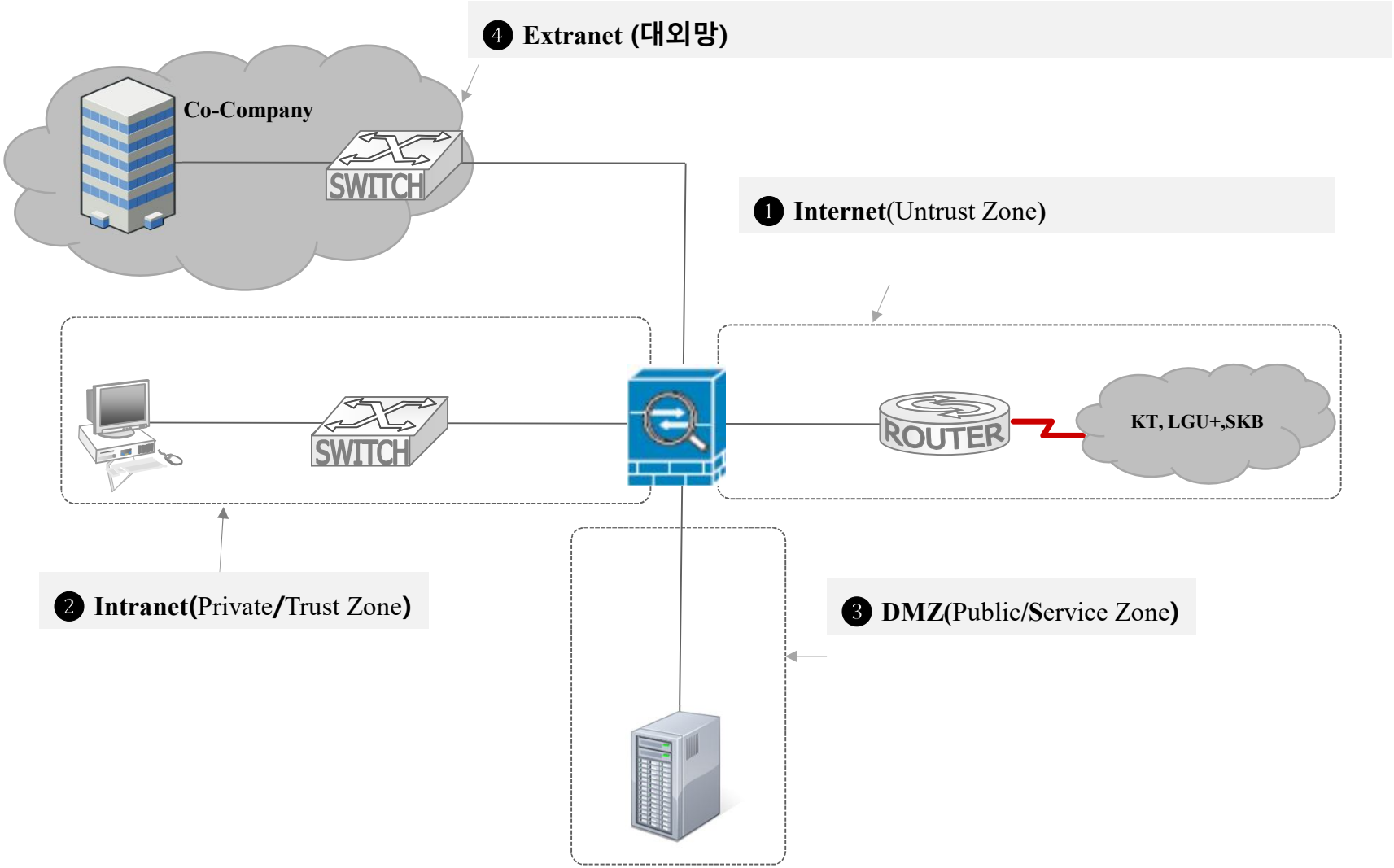
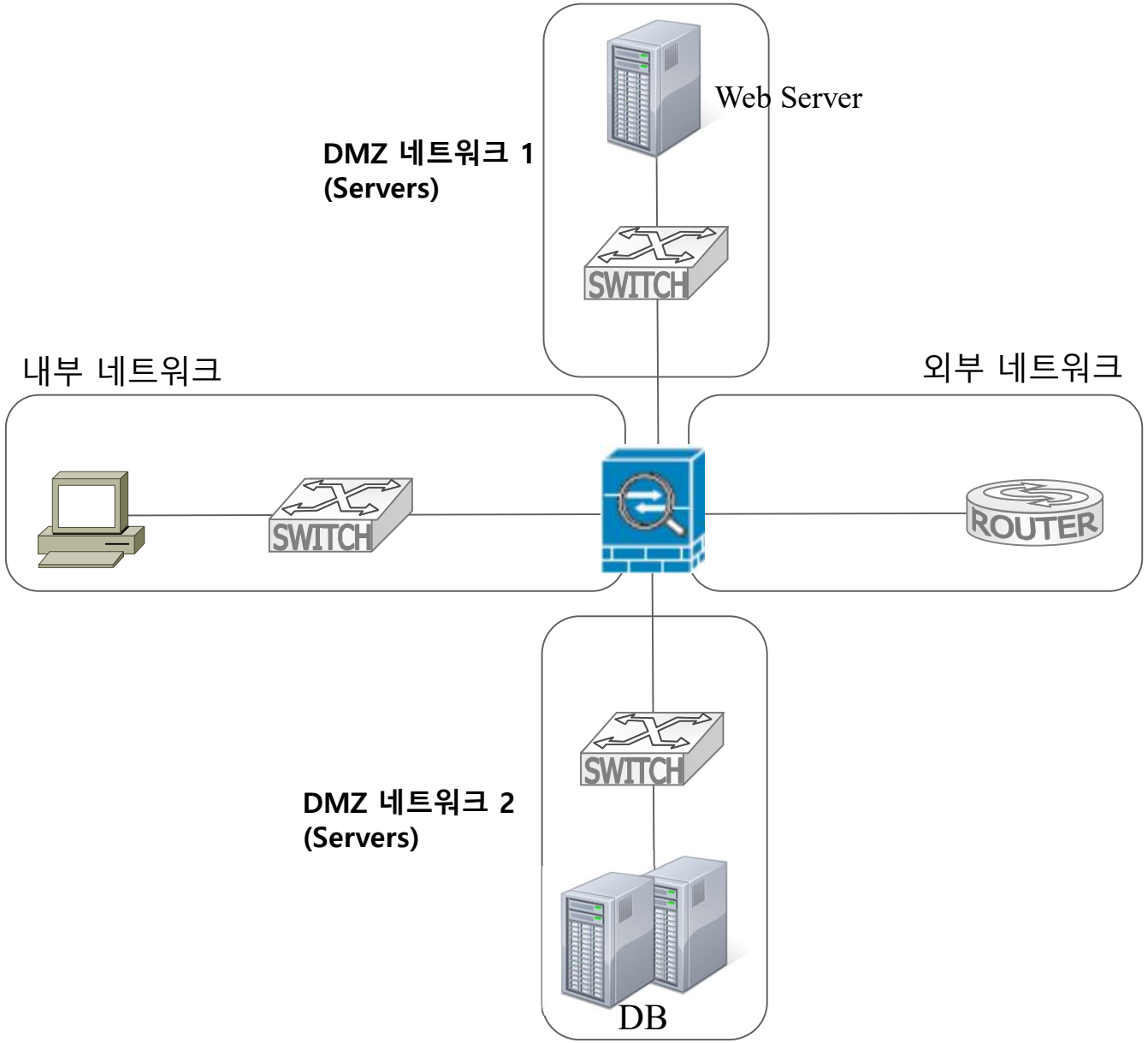
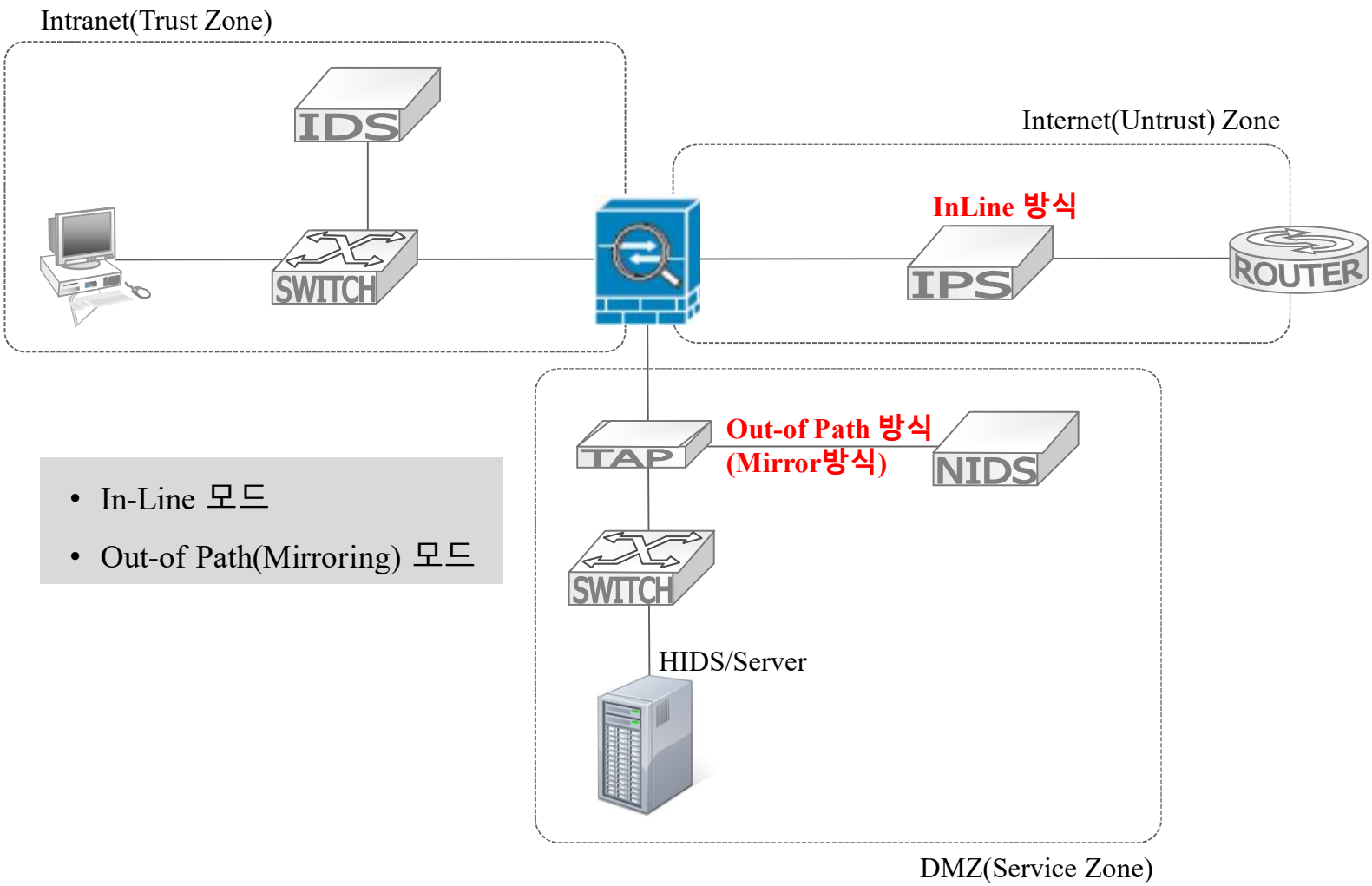
1. 망 구성도


❶ Internet(Untrust Zone)
SWITCH
ROUTER
KT, LGU+,SKB
❷ Intranet(Private/Trust Zone)
❸ DMZ(Public/Service Zone)

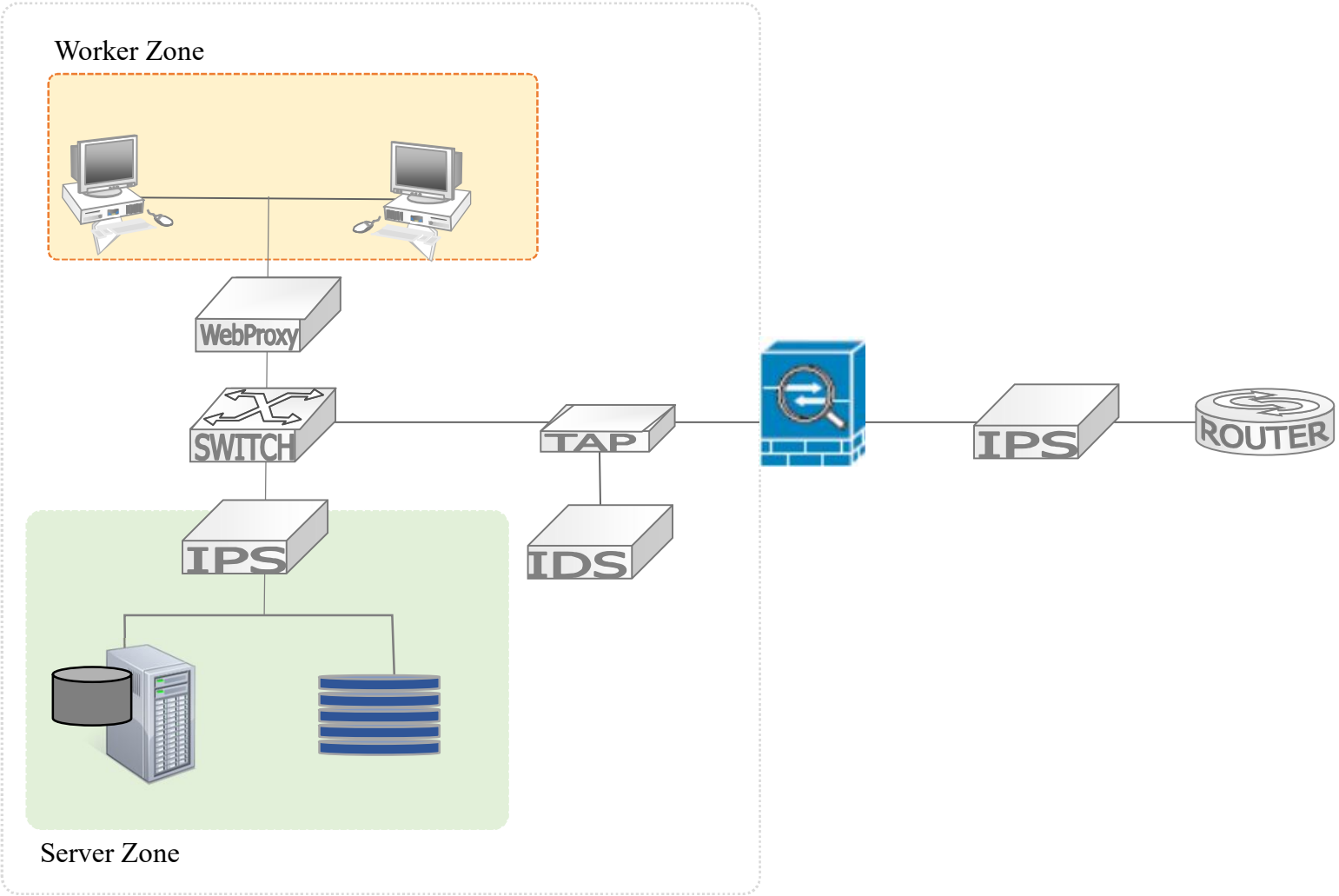

❹ Extranet (대외망)
Co-Company
SWITCH
❶ Internet(Untrust Zone)
SWITCH
ROUTER
KT, LGU+,SKB
❷ Intranet(Private/Trust Zone)
❸ DMZ(Public/Service Zone)


Web Server
DMZ 네트워크 1
(Servers)
SWITCH
내부 네트워크
외부 네트워크
SWITCH
ROUTER
SWITCH
DMZ 네트워크 2
(Servers)
DB

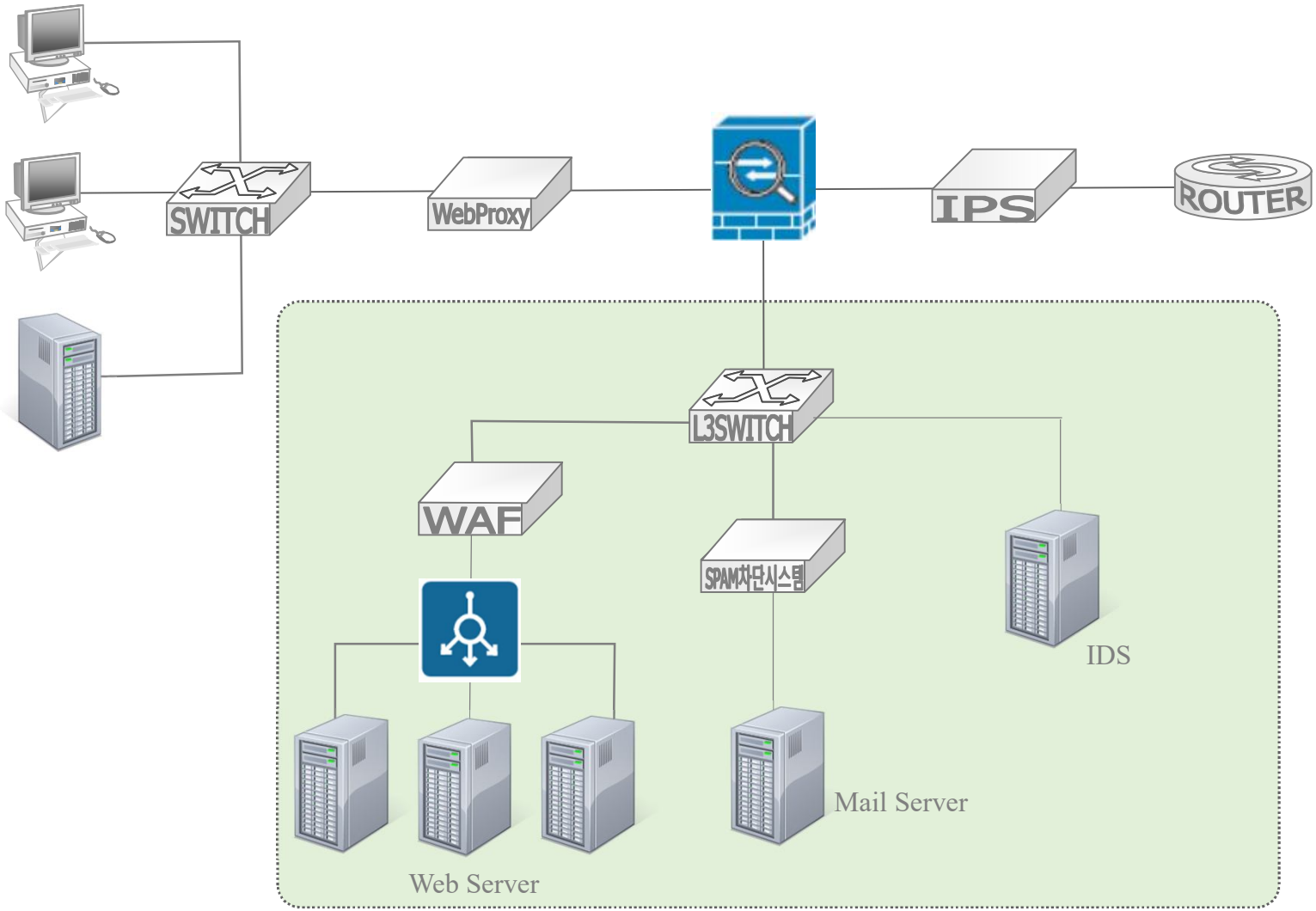
보안 장비 설치 모드



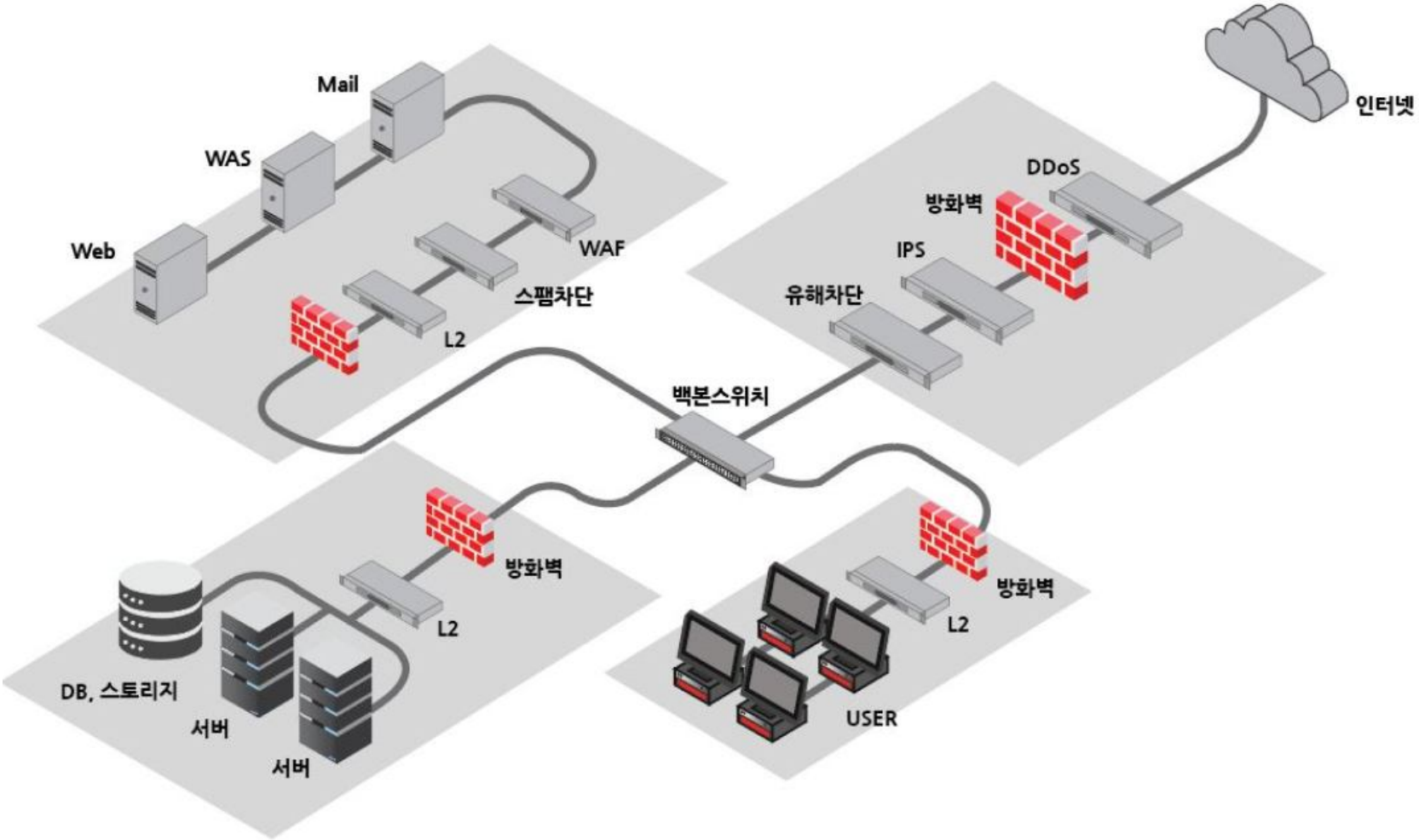
- In-Line 모드
- Out-of Path(Mirroring) 모드

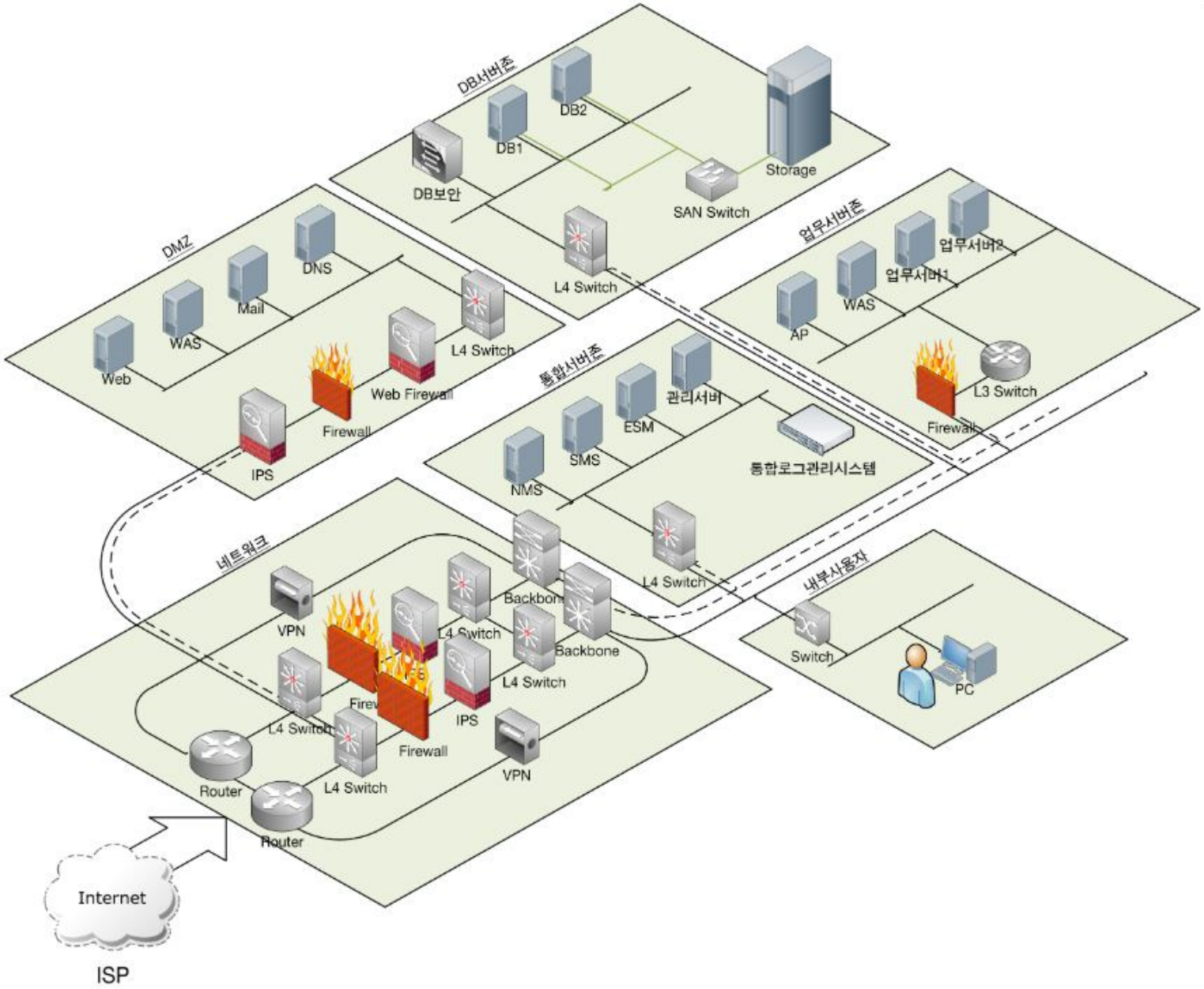


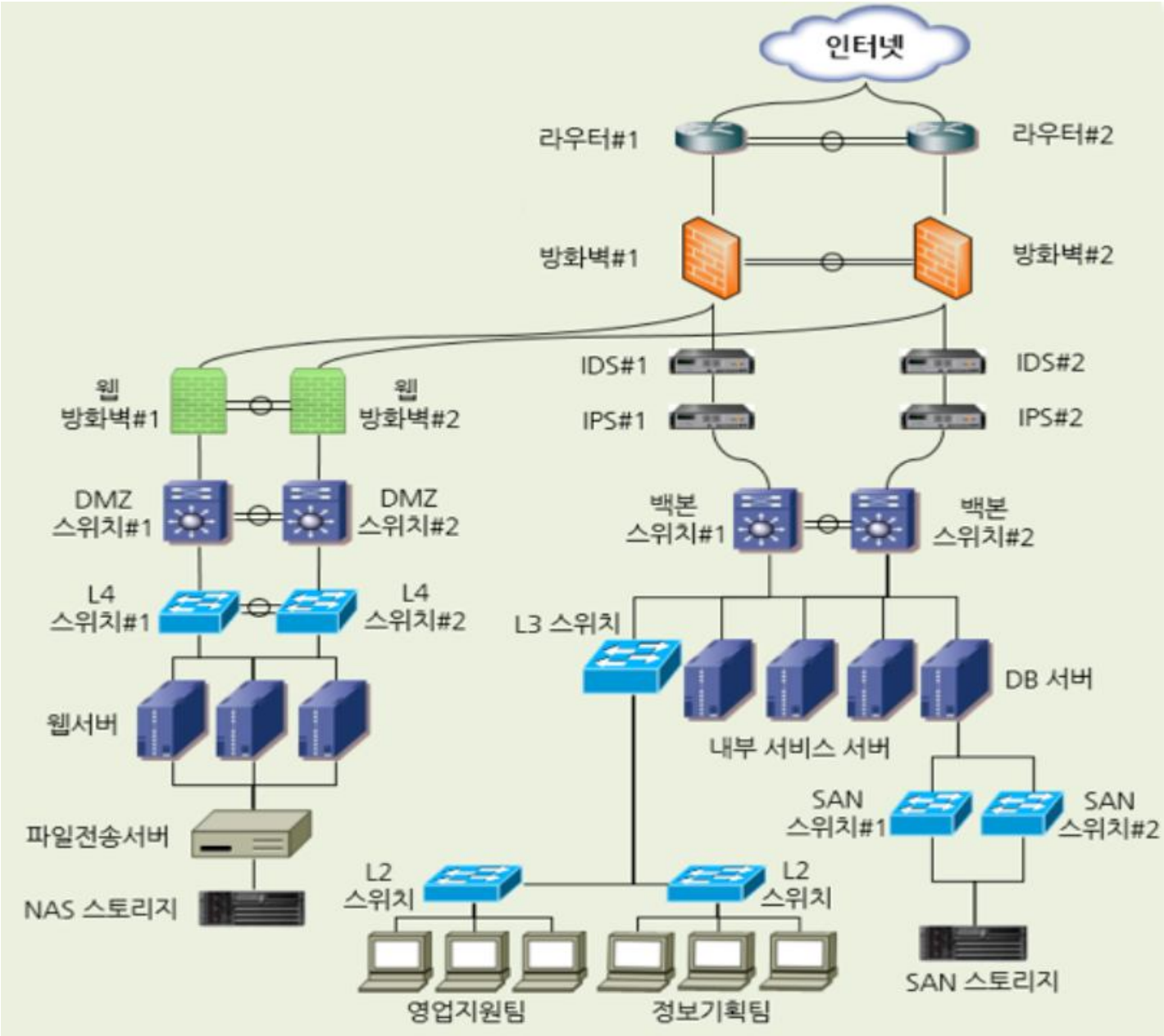
Intranet Zone(Private/Trust)



DMZ Zone(Service/Public)


Mail
WAS
Web
WAF
스팸차단
L2
인터넷
DDoS
방화벽
IPS
유해차단
백본스위치
방화벽
L2
DB, 스토리지
서버
서버
방화벽
L2
USER

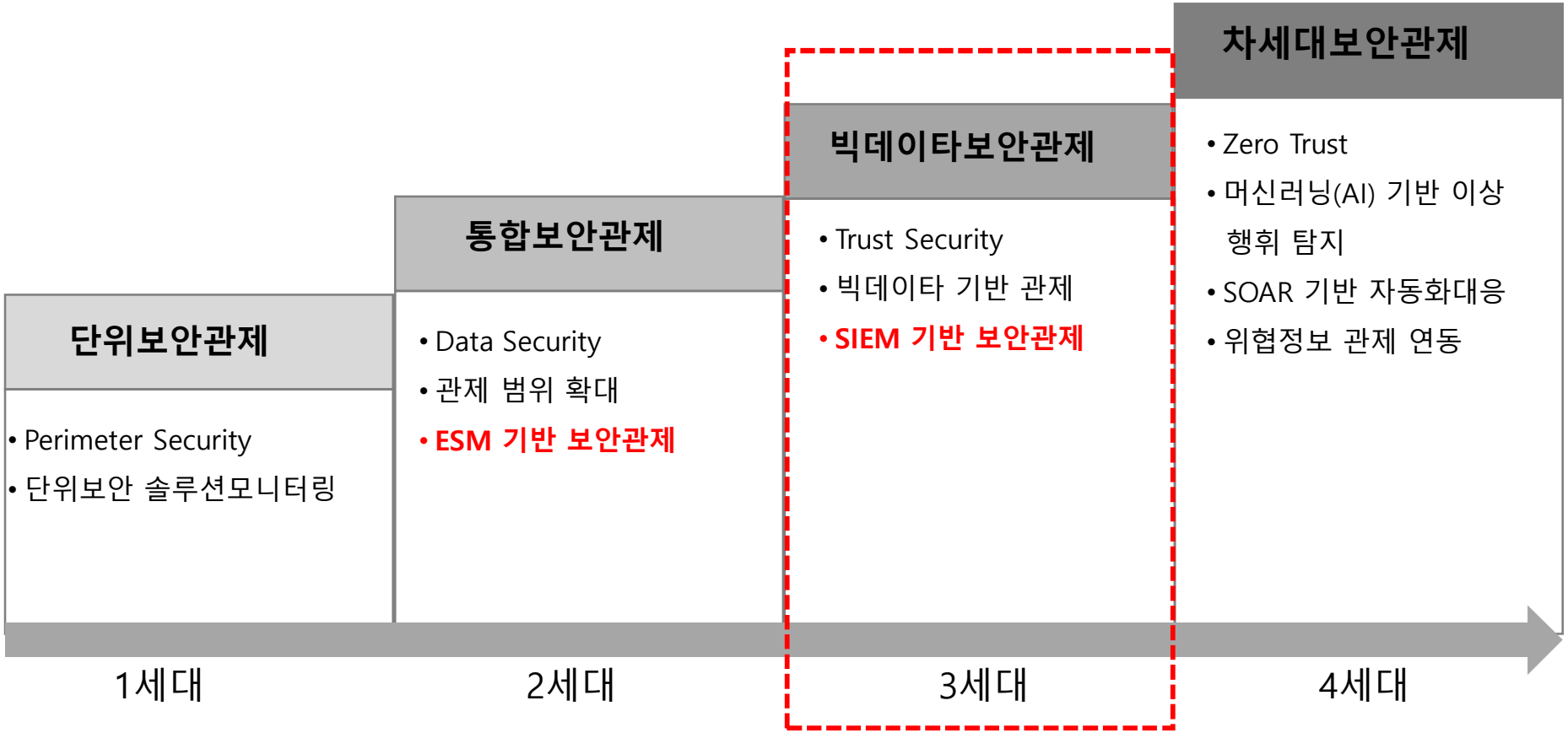

DB서버존
DB2
DB1
DB보안
Storage
SAN Switch
L4 Switch
DMZ
DNS
Mail
WAS
Web
L4 Switch
Web Firewall
Firewall
IPS
업무서버존
업무서버2
업무서버1
WAS
AP
L3 Switch
Firewall
통합서버존
관리서버
ESM
SMS
NMS
통합로그관리시스템
L4 Switch
네트워크
VPN
Backbone
L4 Switch
Backbone
L4 Switch
L4 Switch
IPS
Firewall
VPN
Router
L4 Switch
Router
내부사용자
Switch
PC
Internet
ISP


인터넷
라우터#1
라우터#2
방화벽#1
방화벽#2
IDS#1
IDS#2
IPS#1
IPS#2
웹
방화벽#1
웹
방화벽#2
DMZ
스위치#1
DMZ
스위치#2
백본
스위치#1
백본
스위치#2
L4
스위치#1
L4
스위치#2
L3 스위치
DB 서버
웹서버
내부 서비스 서버
SAN
스위치#1
SAN
스위치#2
파일전송서버
L2
스위치
L2
스위치
NAS 스토리지
SAN 스토리지
영업지원팀
정보기획팀

2. Management Solution

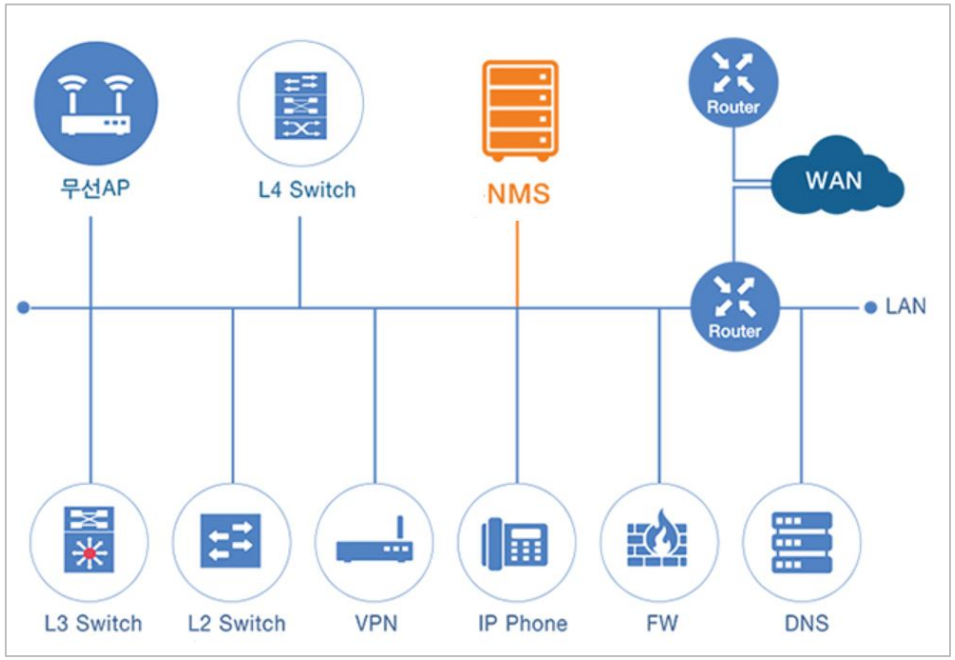
- NMS(Network Management System)
- SMS(Server Management System)
- ESM(Enterprise Security Management)
- SIEM(Security Information & Event Management)
- Network Maintenance Tools

세대 별 보안 관제 시스템


단위보안관제
• Perimeter Security
• 단위보안 솔루션모니터링
통합보안관제
• Data Security
• 관제 범위 확대
• ESM 기반 보안관제
빅데이타보안관제
• Trust Security
• 빅데이타 기반 관제
• SIEM 기반 보안관제
차세대보안관제
• Zero Trust
• 머신러닝(AI) 기반 이상 행휘 탐지
• SOAR 기반 자동화대응
• 위협정보 관제 연동
1세대
2세대
3세대
4세대

2.1 NMS(Network Management System)

- 기관이 정한 요구사항을 만족을 위해 네트워크 장비를 관리하는 시스템
- 네트워크 장비에 대해 구성관리, 장애관리, 성능 관리, 보안관리, 계정관리 기능을 가짐
- NMS 운영을 위해 사용하는 프로토콜 : SNMP, CMIP, RMON 등



1) NMS 기능

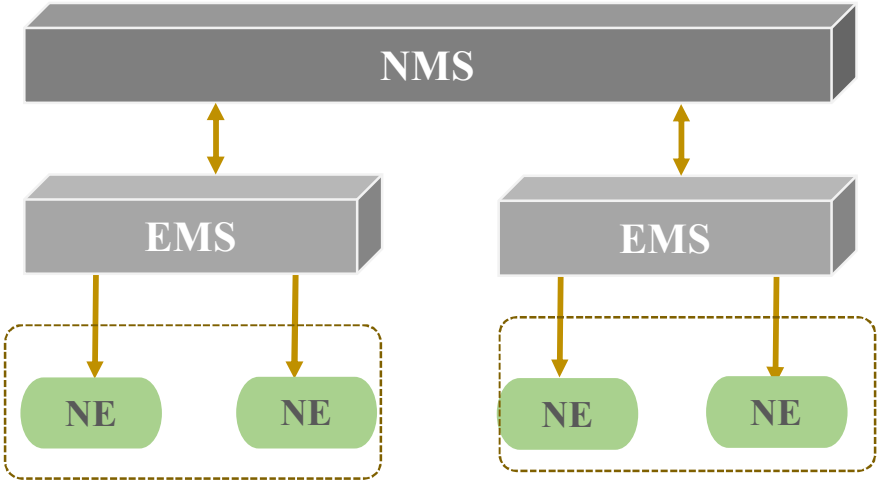
구성관리	네트워크 관련 장비들의 구성현황 파악 및 설정관리
장애관리	장애가 발생했을 때 이를 즉각 대응하여 장애를 최소화 할 수 있도록 하는 사후 관리 주력
성능관리	모니터링과 제어를 통해 네트워크가 효율적으로 운영되도록 관리 속도, 트래픽, 처리량, 응답시간 등의 측정 가능한 기준으로 성능을 나타냄
보안관리	네트워크의 접근 통제(비인가된 접근으로 부터 보호) 방화벽과 같은 침입제어시스템들로 관리
계정관리	과금을 통해 네트워크 자원에 대한 사용자 접근통제 계정 별 네트워크 이용량에 따른 요구 부하 기능

2) NMS 장비 성능 관리 항목

- 관리대상 장비의 CPU와 메모리에 대한 사용률(평균값, 최대값) 측정, 분석
- 관리대상 장비성능을 장비별, 지역별, 기간별(시간별, 일별, 주간별, 월별)로 측정, 분석
- 장비 성능에 대한 임계치 관리 방식에 따른 정보체계 구축 및 관리
- IPS, IDS, F/W 장비의 S/W적인 문제(성능)은 배제

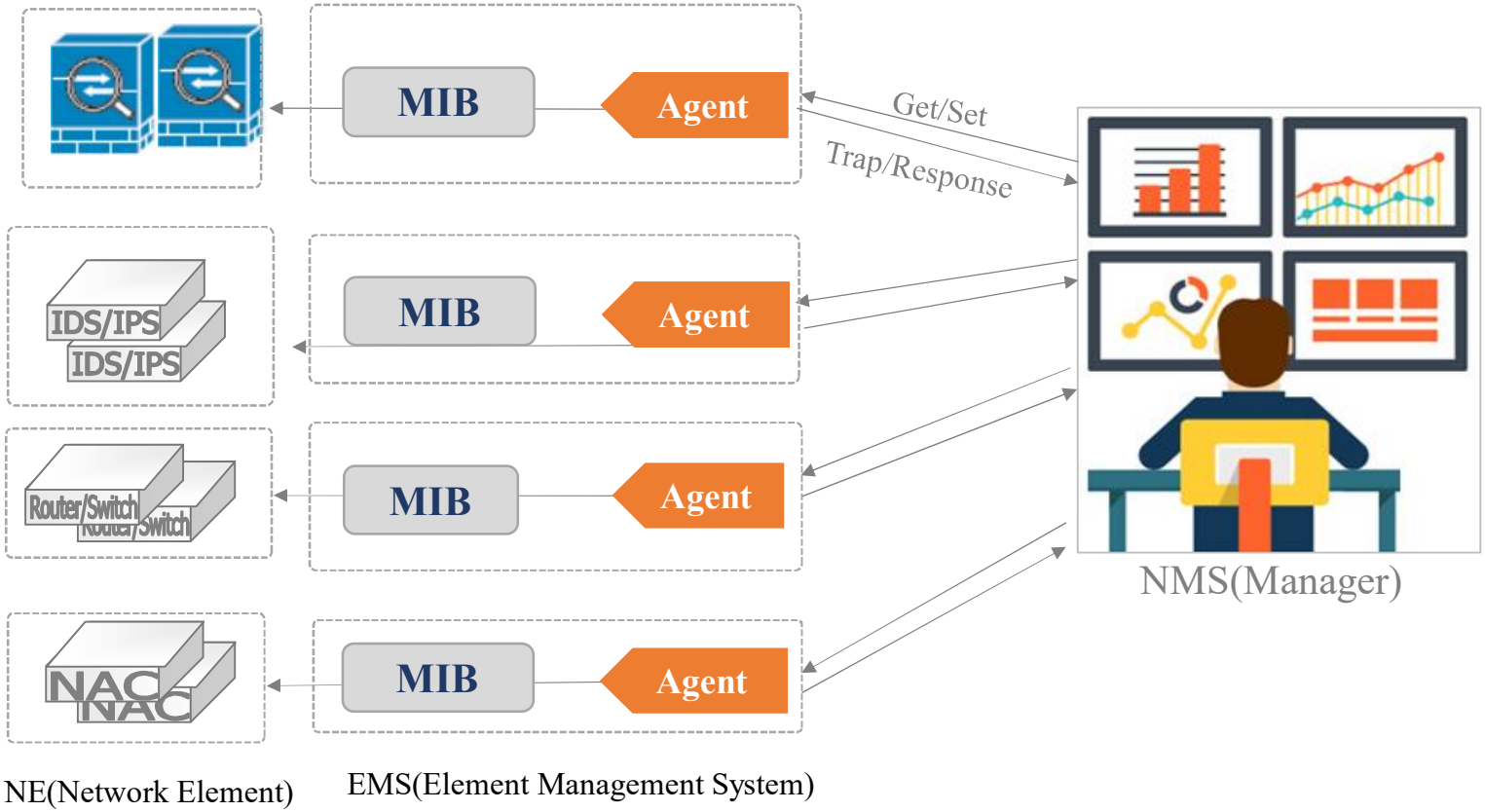
*** 장비자체의 성능 측정으로 제한**

3) NMS & EMS



Element Management System(EMS)

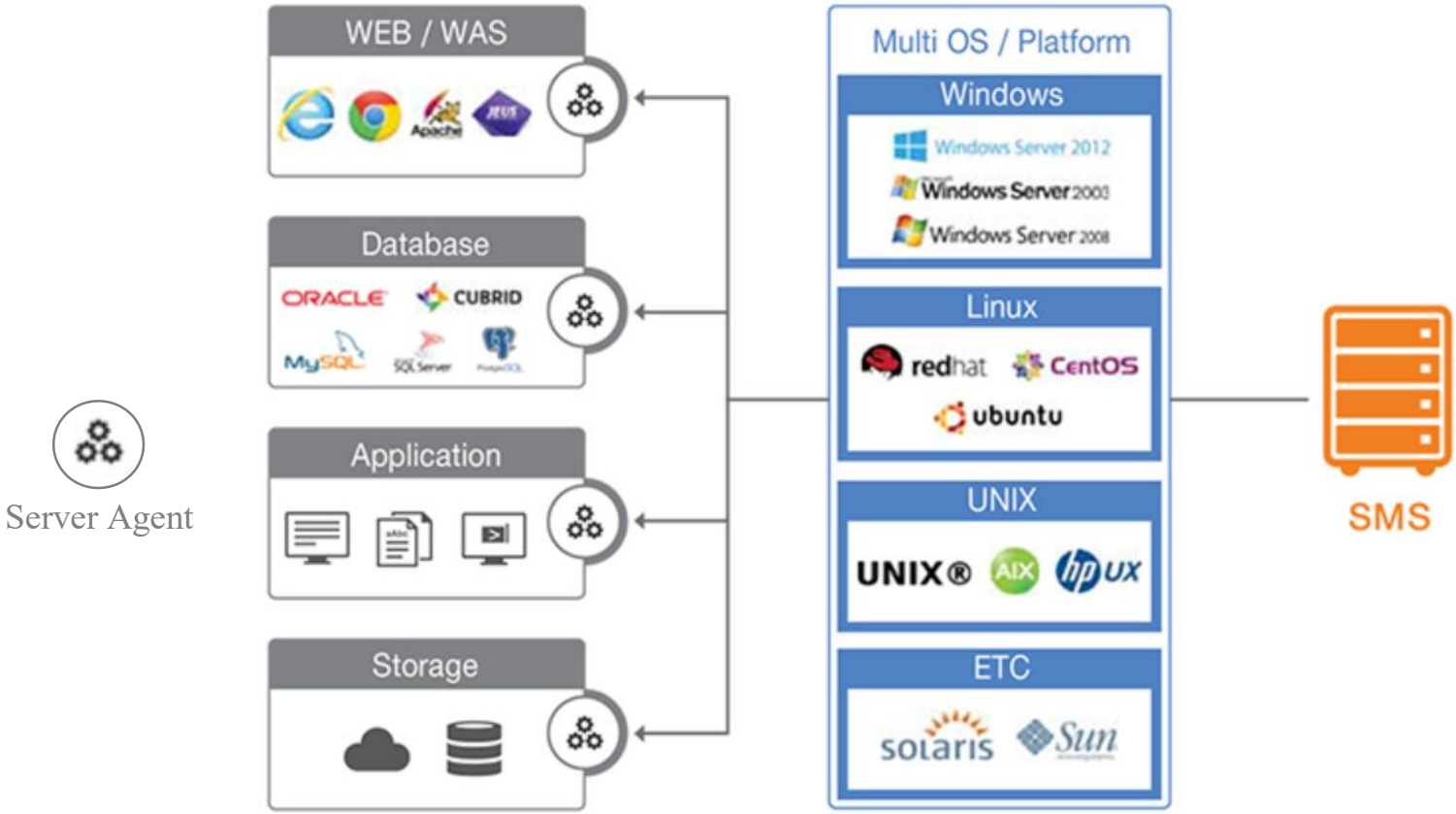
- 장비 관리 시스템 또는 통신망 장비 관리 시스템
- 통신망 장비를 네트워크를 통해 감시 및 제어를 할 수 있는 시스템
- 주로 동일 기종의 장비 관리에 주안점을 두고 있음
- EMS는 해당 서브네트워크를 관리
  - 상위계층인 NMS(Network Management System)으로부터의 요구를 수행
  - 관리대상인 NE(Network Element)들을 제어



- NMS (EMS 전체) : 기관이 정한 요구사항 만족을 위해 네트워크 장비를 관리하는 시스템
- EMS(각 단위별로) : 단위장비 집합을 관리하는 시스템

2.2 SMS(Server Management System)

- 이기종 다양한 서버들의 성능/장애 통합 감시 및 조치



1) SMS 기능

서버 성능 종합 모니터링	• 사용자가 변경 가능한 서버 종합 요약 정보 제공 • 지역별/그룹별/업무별 서버 운영상태 종합 모니터링 • CPU, 메모리, 디스크 사용률, 프로세스, 네트워크 트래픽, 디스크 I/O 등의 성능을 실시간으로 감시
서버 성능 데이터 분석과 예측	• 다양한 관점의 성능 자원에 대한 실시간 흐름 상호 비교 분석 기능 • (CPU, Memory, Disk, Disk I/O, Process, Session 등) • 성능 항목 간 관계성 확인 및 분석 정보 제공 • 수집 성능 정보에 대한 최소, 최대, 평균값에 대한 이력관리 기능 제공

1) SMS 기능

과부하 프로세스 감시와 제어	• 서버에 운영 중인 모든 프로세스 리스트 모니터링 • 프로세스 종료 및 구동 우선순위 변경 기능 • 서비스 프로세스의 동작 상태/개수, 사용 서비스 포트 관리 기능 • 중요 프로세스에 대한 시작, 중지 스크립트 기능
어플리케이션 로그와 서비스 포트 감시	• 어플리케이션 로그 및 서비스 포트를 이용한 장애 여부 확인 기능 • 장애 사항에 대한 이력화 및 분석 자료 활용 • 그룹, 이벤트 등급, 필터링 로그 그룹별 로그 발생 현황 정보 제공
비인가 사용자 차단과 통제	• 서버 별 접속 사용자, 패스워드 변경, 불법사용자 현황 등 강화된 서버 보안관리 기능 • 접근 권한 및 패스워드 정책을 통해 불법사용자에 의한 시스템 접근 및 정보 유출을 방지

2.3 ESM(Enterprise Security Management)

- 통합보안 관제 시스템

  - 기업 보안관리 시스템(통합보안 관리 시스템, 전사적 보안관리 시스템)

  - 다양한 보안 솔루션을 하나로 모은 통합 보안 관리시스템

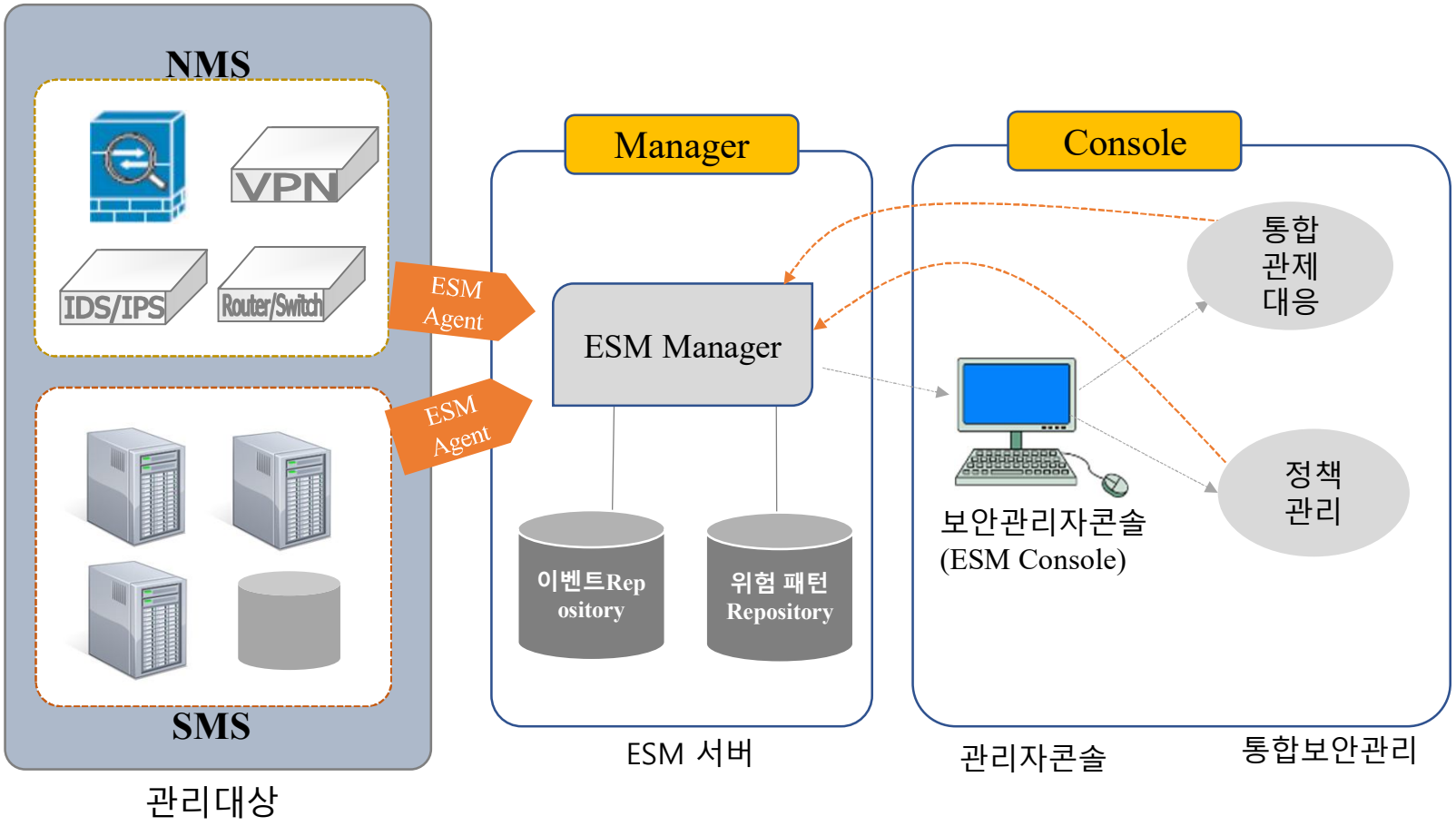
  - 다양한 보안 장비에서 발생하는 로그, 보안 이벤트를 통합적으로 수집, 관리, 분석, 통보 대응 및 보안 정책을 관리

- ESM 주요 기능 2가지

  - 서로 다른 기종의 보안 장비들을 통합 관리 기능

  - 네트워크 자원 현황을 모니터링하는 보안 모니터링 기능

1) ESM(Enterprise Security Management) 구조



Agent	• 관리 대상 보안 장비(보안장비, 시스템장비, 네트워크 장비)에 설치 • 사전에 정의된 규칙에 의한 이벤트 수집 및 보안 정책 반영 • 정책에 따른 로그 및 이벤트 데이터를 수집하여 ESM manager에 전달
Manager (Engine)	• ESM agent에 의해 수집된 데이터 분석및 저장 • 분석 결과를 ESM Console에 전달
Console	• ESM Manager에 의해 전달된 정보의 시각적 전달, 상황 판단 및 리포팅 기능 제공 • ESM Manager/Agent에 대해 규칙을 제어/통제 수행

2.4 SIEM(Security Information & Event Management)

- SIEM(Security Information & Event Management)
- ESM의 진화된 형태 (2015년 가트너에 의해 처음으로 도입된 개념)
- 기업 정보에 대한 종합 관제 솔루션
- HP 아크사이트(ArcSight), IBM 큐레이더(Qrader), Splunk 등이 널리 쓰임

1) 주요기능

- 다양한 이기종 장비에서 발생하는 로그를 통합 수집하고 분석

- 로그 분석을 통해 각종 공격과 정책 위반을 탐지와 경고

❶ SIEM 탐지기법 : 시그니처 탐지기반과 이상행위 탐지기법 모두 활용

❷ 정책 위반을 탐지하면 곧 경고를 생성하고 보안 담당자에 통보

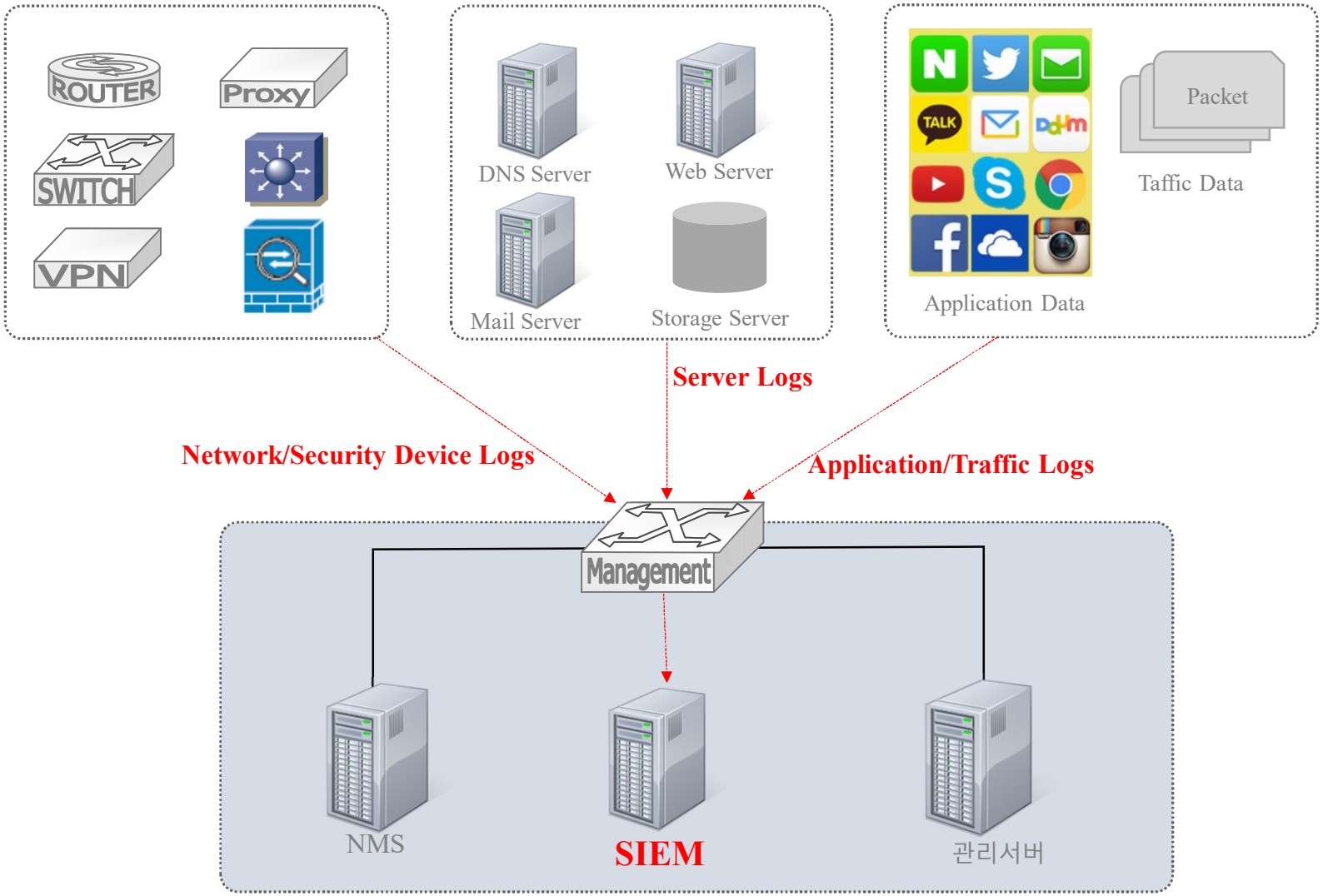
* 보안 이상 징후가 발생하는 즉시 탐지하는 실시간 대응이 어려움

❸ 경고를 발생시키는 정책은 기업이나 기관의 관심사안에 따라 다름

❹ 경고는 중요도를 부여할 수 있어야 하며 중요도에 따라 향후 상세 분석 여부 결정

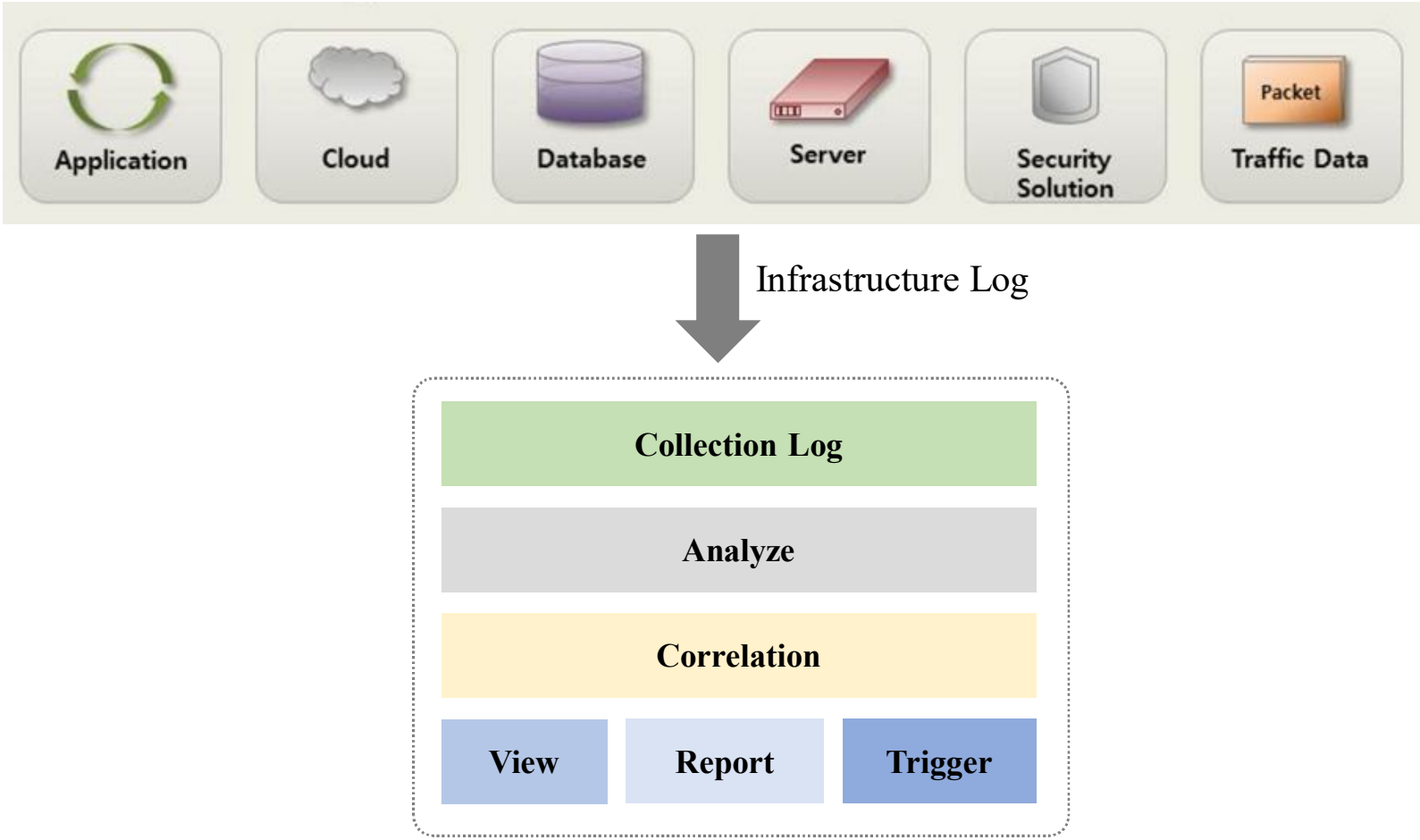
- 보고서 생성(로그를 보고서로 변환)

(예) 얼마나 많은 접속이 발생했는가? 가장 많은 접속을 일으키는 어떤 것인가?



Management Zone or **OoB(Out of Band)**

2) 구조

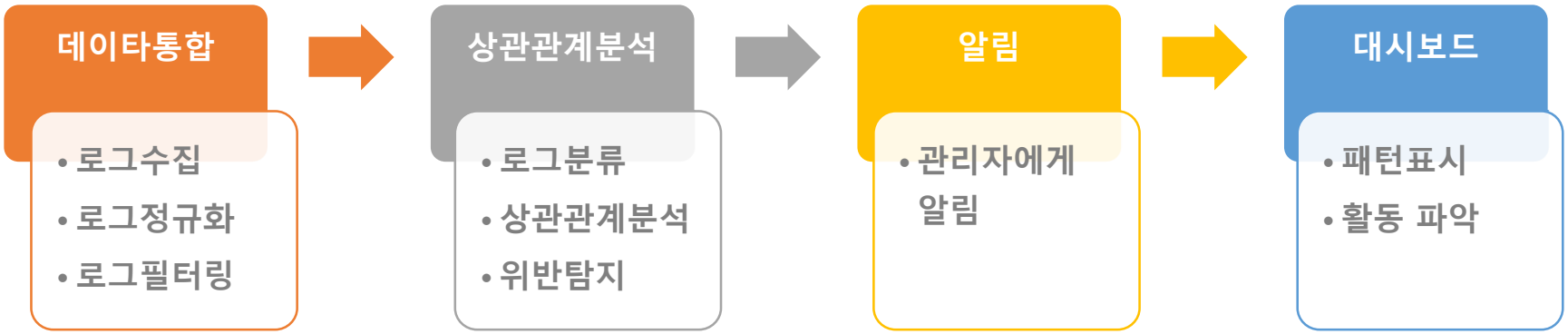

Application
Cloud
Database
Server
Security Solution
Packet
Traffic Data
Infrastructure Log
Collection Log
Analyze
Correlation
View
Report
Trigger

3) SIEM과 ESM 비교

	ESM	SIEM
정의	• 기업 내 다양한 보안시스템을 관제/운영/관리하여 중앙에서 통합적으로 보안 현황을 모니터링 하는 시스템	• 기업 내에서 발생하는 모든 자원의 정보 및 보안 이벤트를 통합 관리 ➔ ***장애처리 관점에서 운영 및 심층분석, 규제 준수 관점으로 확대***
수집 • 저장	• 정형데이타 기준, 원본로그 보관안함 • 수집 데이터 보존기간 :1~2개월	• 정형/비정형데이타 수용, 원본로그 보관 • 수집 데이터 보존기간 :1년 이상 ➔ ***광범위 데이터 처리 및 장기간 보관***
위협 탐지	• IP, Port 등 시그니처 중심의 네트워크 계층 탐지 • 단순 패턴 기반 탐지 • 알려진 공격 위주 분석 • 단시간(최대1일) 범위 분석	• IP, Port 외 애플리케이션, 프로토콜 등 연관성 분석 및 탐지 • APT 등 알려지지 않은 공격 및 공격간의 연관성 분석, 정상상태에서의 정보위협분석 • 장시간(수개월) 범위 분석 ➔ ***심층분석, 연관분석 지원***

	ESM	SIEM
수집·분석	• Event 위주의 단시간(최대1일) 위협분석 • RDBMS 기반 상관분석 및 리포트, 중앙처리 구조 • 초당 3천 건 내외 수집/분석 포함	• 빅데이타 수준의 장기간(수개월) 심층분석 • Indexing, MapReduce 등 빅데이타 처리 기반 상관분석 및 리포트 • 초당 3만~5만건 이상 수집/분석 ➔ *RDBMS 기반의 처리 속도 지연 극복*
시각화	• 대시보드, 정형보고서 제공	• 대시보드, 정형보고서, 사용자 보고서, 시각화 보고서 제공 ➔ *다양한 Report 제공*
사용자	• 보안관리자, 관제 요원 위주	• 보안관리자, 관제요원 • 각업무시스템 별 담당자 • 개인정보보호담당자 • 대외 서비스 담당자 ➔ *사용자 관점의 다양한 view 지원*
하드웨어	• 고가의 유닉스 서버 스템	• 저가의 리눅스 x86 시스템

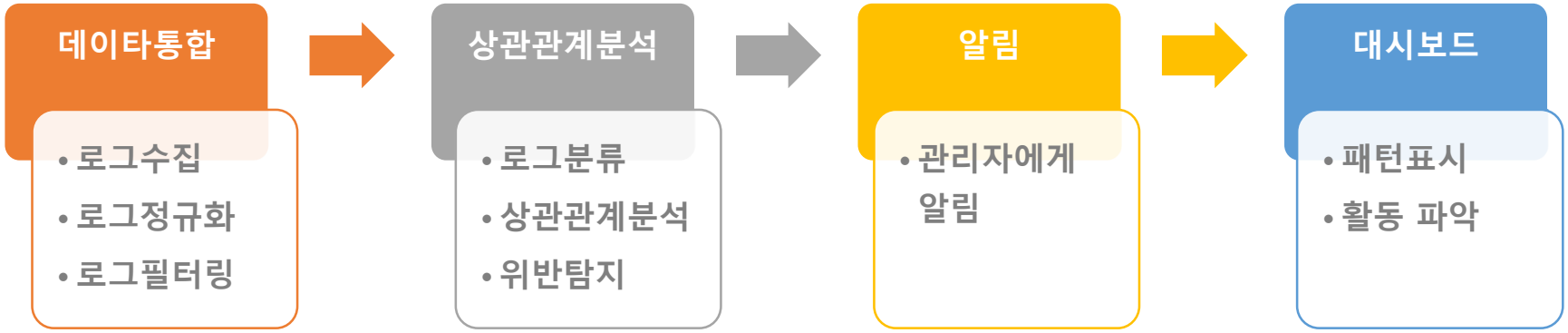
4) SIEM 개략적 처리 프로세스



데이터통합

- **로그수집(collection)**
  - 관제 대상의 Agent, SNMP, Syslog 서버로부터 로그 수집

- **로그정규화(normalization)와 필터링(filtering)**
  - 로그 형식을 표준 형식으로 변환
  - 수집한 이벤트나 플로우 데이터를 데이터베이스에 저장하려면 일정한 형태로 변환 필요
  - 업체에 따라 자동 정규화 또는 수동 정규화 방법 사용
  - 정규화 과정에서 불필요한 데이타 필터링 수행



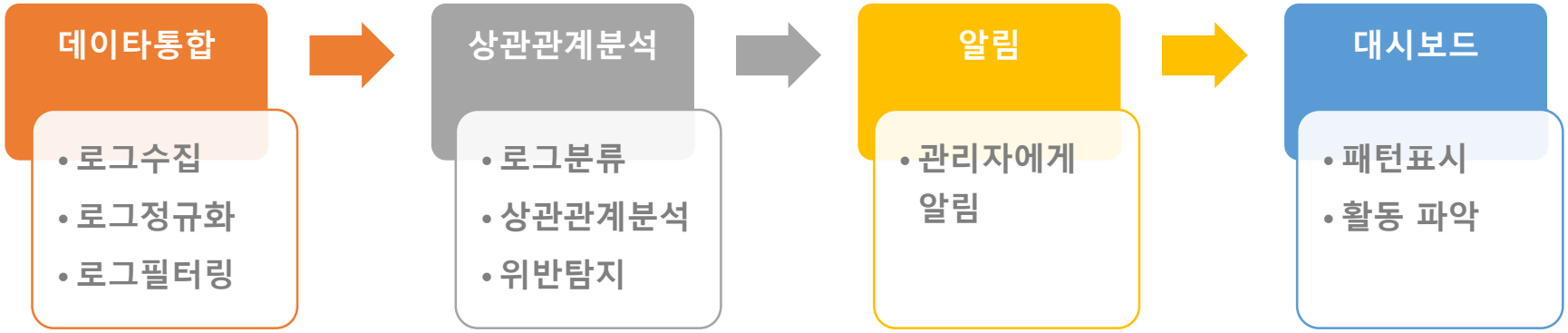
상관관계분석

로그분류

- 수집한 이벤트나 플로우 데이터를 데이터베이스에 저장하려면 일정한 형태로 변환
- 업체에 따라 자동 정규화 또는 수동 정규격화 방법 사용
- 정규화 과정에서 불필요한 데이타 필터링 수행

상관관계분석(Correlation)

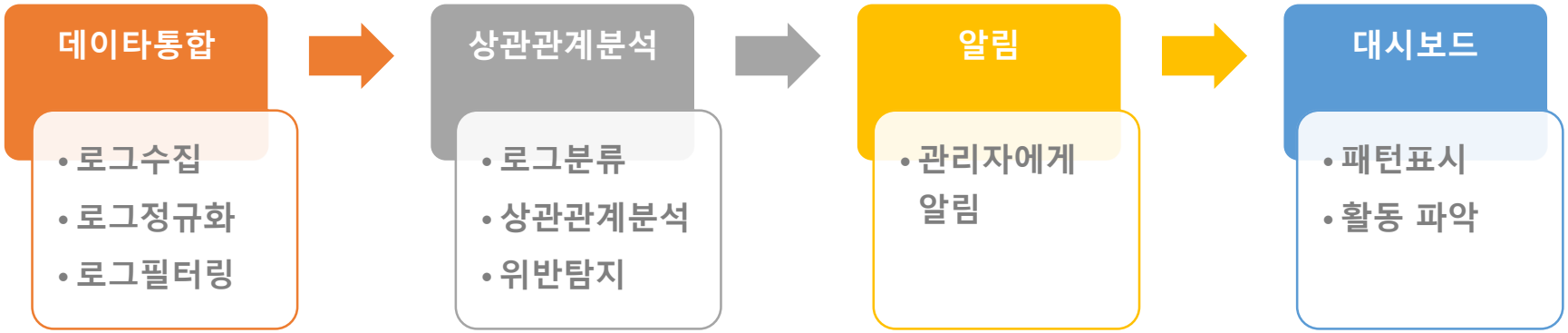
- 동기종 또는 이기종의 여러 보안 솔루션에서 발생하는 로그 패턴간에 연관성 분석
- 로그들간에 상호연관 분석을 함으로써 실시간 보안 위협을 파악하고 대응



상관관계분석

위험 탐지

- 로그를 분석해서 보호 대상의 전산 환경에 발생하는 문제와 공격과 정책의 위반 탐지
- 탐지는 설정한 규칙이나 조건에 맞을 때 발생
- 탐지 규칙은 임계값을 초과하거나 통계 기반의 사용자 행위를 분석하는 방법이 있음



알림(alert)

- **관리자에게 알림**

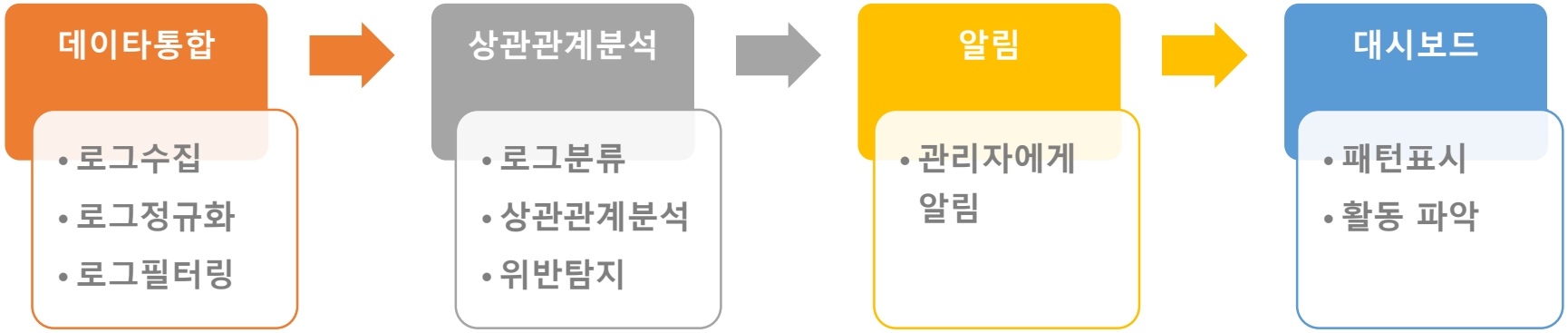
  - 경고란 보안 담당자의 검토가 필요하다는 의미

  - 정책 위반을 탐지하면 곧 경고가 생성하고 보안 담당자에게 통보

  - 경고를 발생시키는 정책은 운영하는 기업이나 기관의 관심 사안에 따라 다름

  - 경고는 중요도를 부여 할 수 있어야 함

  - 중요도는 해당 경고를 향후 상세 분석을 할 것인지를 결정하는 기준으로 사용



대시보드

- 로그는 보고서 또는 대시보드로 변환 될 수 있음
  - 얼마나 많은 접속이 발생했는가?
  - 가장 많은 접속을 일으키는 호스는 어떤 것인가?
  - 가장 많은 데이터를 인터넷으로 전송한 호스트는 무엇인가?
  - 해당 호스트를 사용하는 사용자는 누구인가?